

AUDITORIA DE SEGURANCA

Relatorio de Auditoria de Seguranca

lista-de-tarefas

Data: 18/09/2026. Escopo: rotas de API (src/app/api), frontend (src/components, src/app), autenticacao e banco (src/lib, prisma), CI e historico git. Snapshot auditado: HEAD efc8dda + ajuste em globals.css.

Stack: TypeScript + Next.js 16 App Router, Prisma + PostgreSQL sem RLS, better-auth com sessoes em cookie, deploy Vercel, CI GitHub Actions. Sem Docker/Helm/Terraform, sem upload de arquivos, sem server actions.

Metodologia: (1) isolamento = filtro manual por userId; (2) permissao = N/A por desenho, sem papeis no modelo; (3) IDOR = todos os handlers por ID, sem amostragem; (4) segredos = grep + historico git + bundle; (5) XSS = sinks do React + URLs + saidas do backend. Segunda passagem de validacao + sondas empiricas em producao (filtros UUID). So reportado o comprovado no codigo.

Resumo executivo

Auditoria completa sem amostragem: 8 arquivos de rota (53 acessos ao banco), 18 componentes, configuracao de auth, CI e historico git. Resultado: 0 criticas, 0 altas, 0 medias, 0 baixas e 1 informativa. Nenhuma vulnerabilidade exploravel encontrada; o unico registro e uma observacao de ciclo de vida da conta (sem recuperacao de senha, exclusao ou 2FA).

Achados por severidade



Info - 1 achado

0 criticas, 0 altas, 0 medias, 0 baixas.

Achados por categoria

1. Isolamento		0
2. Permissao		0
3. IDOR		0
4. Segredos		0
5. XSS		0
6. Conta		1

Categorias 1 a 5 zeradas: isolamento, IDOR, segredos e XSS integros; categoria 2 nao se aplica (sem papeis). Pontos fortes verificados: 14.

Pontos fortes

Autenticacao

- Sessao recuperada server-side via better-auth em todas as rotas de API e no layout (app) com redirect (src/app/(app)/layout.tsx; src/app/login/page.tsx; src/app/register/page.tsx).
- Rate limit do better-auth habilitado (auth.ts:26-30); endpoints de sign-in/sign-up/change-password com regra especial 3 req/10s (fonte instalada da lib).
- Origens confiaveis por ambiente, sem localhost em producao (auth.ts:18-24); segredo de sessao validado no boot (auth.ts:6-10).
- Troca de senha exige a senha atual e revoga as demais sessoes (ChangePasswordForm.tsx:43-47); callbackURL e redirects fixos, sem open redirect.

Autorizacao

- NÃO APLICÁVEL por desenho: modelo User sem campo de papel e nenhum gate de role no frontend (grep role/isAdmin vazio); privilegio unico para todo usuario autenticado; nenhum endpoint administrativo existe.

Isolamento

- Filtro manual por userId em 100% dos 53 acessos Prisma (8 arquivos de rota); sem listagens, agregacoes, relatorios ou export sem escopo de dono.

Protecao contra IDOR

- PUT/DELETE validam posse via findFirst/updateMany/deleteMany com userId; updates por id precedidos de findFirst (ex: tasks/route.ts:351-360); reorder com pre-contagem ownedCount === ids.length (tasks/route.ts:301-307); restore/purge exigem deletedAt + userId; vinculos com checagem de posse (tasks/route.ts:43-48; notes/route.ts:94-113,208-226; timer/route.ts:84-93; subtasks/route.ts:7-9).

Gestao de segredos

- Segredos apenas via env; .env nunca commitado (historico verificado); .env.example so com placeholders; CI com URL dummy local; sem NEXT_PUBLIC; Google OAuth com secret restrito ao servidor (auth.ts:88-97); sem chaves no bundle.

Sanitizacao/XSS

- Zero sinks (sem dangerouslySetInnerHTML/innerHTML/eval/markdown) nos 18 componentes; conteudo de usuario renderizado como nos de texto do React; sem URLs controladas pelo usuario em href/src (apenas blob: local e link fixo); sem e-mail/HTML no backend.

Infraestrutura

- Security headers (next.config.ts); CSRF via Origin check em 16 handlers + cookies HttpOnly/SameSite-Lax/Secure; sem Docker/Helm/Terraform; deploy Vercel + CI com lint, typecheck, testes e build.

Pontos fracos

Sem linguagem alarmista: ha um unico ponto de atencao, informativo e nao exploravel por terceiros - o ciclo de vida da conta (SEC-001). Todo o resto verificado esta protegido, conforme a matriz de cobertura.

Tabela de achados

ID			
SEC-001	Conta (ciclo de vida)	INFO	
			src/lib/auth.ts:101-104 (+ ausencia verificada em src/) Nao ha recuperacao de senha self-service, exclusao de conta nem 2FA. Grep por forget-password/resetPassword/deleteUser/twoFactor retorna vazio; emailAndPassword nao configura verificacao.

[SEC-001] Ciclo de vida da conta incompleto: sem recuperacao de senha, exclusao de conta ou 2FA

Categoria: Conta (ciclo de vida)

Severidade: INFO

Arquivo: src/lib/auth.ts:101-104 (+ ausencia verificada em src/)

Linha: 101-104 (+ ausencia verificada em src/)

Rota/Funcao: N/A (fluxo inexistente)

Evidencia

```
src/lib/auth.ts:101-104
emailAndPassword: { enabled: true, autoSignIn: true } // sem recovery/2FA
grep forget-password|resetPassword|deleteUser|twoFactor em src/: vazio
```

Analise

O que acontece: nada - os fluxos nao existem. Por que: nunca implementados; recuperacao depende de SMTP externo (mesmo bloqueador do e-mail de verificacao). A entrada do usuario nao chega a ponto vulneravel porque o ponto nao existe. Protecoes existentes (troca de senha autenticada com senha atual + revokeOtherSessions) cobrem apenas usuarios logados.

Condicao de exploracao

Nao exploravel por terceiros (sem pre-condicao de atacante): o risco e lockout permanente se o usuario esquecer a senha (recuperacao so via banco) e ausencia de self-service para exclusao (LGPD art. 18).

Impacto

Disponibilidade da propria conta e conformidade de privacidade. Sem impacto em confidencialidade/integridade de dados de terceiros.

Correcao recomendada

Ativar forgetPassword do better-auth + SMTP; criar endpoint de exclusao de conta com purge em cascata (reuso dos purges existentes); avaliar plugin TOTP de 2FA.

Matriz de cobertura

AREA		
Autenticacao	auth.ts, auth-client, Login/Register/Logout/ChangePassword, api/auth, login/register pages todas as rotas	Protegido
Autorizacao	schema User, grep de papeis, todos os endpoints todas	N/A (sem papeis)
Isolamento	7 rotas de API, 53 acessos Prisma todos os GETs/agregacoes	Protegido
IDOR	16 handlers de mutacao + GETs por ID todos por ID	Protegido
Segredos	codigo, CI, git log, bundle —	Protegido
XSS	18 componentes + saidas da API todas as telas	Protegido
Conta/ciclo de vida	auth + grep de fluxos —	1 info

Nao verificado a partir do codigo (limitacao declarada): variaveis de ambiente do dashboard Vercel, backups do Postgres gerenciado e TLS do provedor de banco.

Recomendacoes priorizadas

P1 - Acao imediata

Nenhuma exigida: zero achados criticos/altos/medios/baixos.

P2 - Alta prioridade

SEC-001: configurar SMTP e ativar recuperacao de senha + verificacao de e-mail; criar exclusao de conta self-service.

P3 - Importante

Manter Dependabot semanal e npm audit periodico; reauditar apos mudancas em auth, rotas ou dependencias.

P4 - Hardening futuro

Expiracao/auto-purge da lixeira, indices compostos (userId, projectId), avaliacao de 2FA TOTP.

Apendice: revalidacao da auditoria anterior

Os 8 achados da auditoria anterior (A1-A8) foram recorrigidos e revalidados nesta passagem:

ACHADO

A1 (media)	clientKey usa x-real-ip/ultimo XFF + tests/rate-limit.test.ts	Corrigido
A2 (media)	reorderSchema .max(200) + teste	Corrigido
A3 (baixa)	trustedOrigins sem localhost em prod	Corrigido
A4 (baixa)	cadastro generico + rateLimit better-auth	Corrigido
A5 (baixa)	assert de secret no boot + CI dummy	Corrigido
A6 (baixa)	isUuid nos GETs (400)	Corrigido
A7 (info)	documentado; bloqueado p/ SMTP	Pendente ext.
A8 (info)	Dependabot + npm run audit	Corrigido

Issues para o GitHub

Texto pronto para copiar e colar, entre os marcadores --- ISSUE n --- e --- FIM ISSUE n ---.

--- ISSUE 1 ---

[Segurança] Ciclo de vida da conta: sem recuperação de senha, exclusão ou 2FA

Descrição

A aplicação não possui recuperação de senha self-service, exclusão de conta self-service nem autenticação em dois fatores. O objeto de configuração emailAndPassword (src/lib/auth.ts:101-104) não habilita nenhum desses fluxos, e a busca por forget-password, resetPassword, deleteUser e twoFactor em src/ retorna vazio.

Por que é explorável

Não é explorável por terceiros (não há ponto de entrada): o risco é operacional — lockout permanente em caso de senha esquecida (recuperação só via banco) e ausência de self-service para exclusão (LGPD art. 18). Por isso a severidade INFORMATIVA.

Evidência

src/lib/auth.ts:101-104

```
````ts
emailAndPassword: { enabled: true, autoSignIn: true } // sem recovery/2FA
````
```

Impacto

Disponibilidade da própria conta e conformidade de privacidade. Sem impacto em confidencialidade/integridade de terceiros.

Sugestão de correção

Ativar forgetPassword do better-auth com provedor SMTP (mesmo bloqueador do e-mail de verificação); criar endpoint DELETE de conta com purge em cascata; avaliar plugin TOTP.

Critérios de aceite

- * [] Fluxo de recuperação funcional de ponta a ponta
- * [] Exclusão remove todos os dados do usuário
- * [] Teste automatizado cobrindo o cenário
- * [] Verificação de regressão realizada

Labels sugeridas: security
informativa

--- FIM ISSUE 1 ---